

You are assisting in Security Requirements Engineering.

INPUT: A structured use-case description (e.g., Markdown) that may include: Preconditions, Main Flow, Sub-flows, Alternatives/Exceptions, Logging, Data Format.

OBJECTIVE:

Perform an end-to-end security analysis of the input use case by:

1. Identifying security-relevant software assets.
2. Assigning criticality to each asset.
3. Identifying realistic, use-case-grounded threats for each asset.
4. Mapping each threat to applicable STRIDE categories and CAPEC attack patterns where justified.
5. Deriving one or more specific, testable security requirements for each threat.

RELATIONSHIP CONTRACT:

- One Asset_ID may map to zero..many Threat_IDs.
- One Threat_ID maps to exactly one Asset_ID.
- One Threat_ID may map to one..many STRIDE_Categories.
- One Threat_ID may map to zero..many CAPEC_References.
- One Threat_ID may map to one..many Requirement_IDs.

DEFINITIONS:

- Asset: An asset is any system element (data, credential, configuration, system component, or state) that has value from a security perspective and whose compromise could impact confidentiality, integrity, or availability.

Asset Fields

- Asset_ID: A unique identifier assigned to the asset (e.g., A1, A2, ...).
- Asset_Name: The asset name extracted or normalized from the use-case text.
- Asset_Type: One of:
 - Asset_Type: A classification of the asset based on its role in the system, using the following categories:
 - Data: Information the system stores, processes, or transmits; often subject to confidentiality and integrity requirements (e.g., medical records, appointment details).
 - Credential: Secrets used to authenticate or authorize a user or system (e.g., password, API key, session token).
 - Configuration: Rules, settings, or policies that control system behavior or access (e.g., role assignment, password format rules, access-control policy).
 - System Component: A software subsystem or service responsible for functionality or

security-relevant behavior (e.g., authentication service, user management module, database, logging subsystem).

- State: Runtime or persisted state representing a current security condition that affects access decisions (e.g., session state, login status, account lockout status, enabled/disabled flag).

- Tools/Techniques: Explicitly mentioned technologies, tools, mechanisms, or methods associated with the asset. If not stated, write Not Specified.

- Criticality: High, Medium, or Low based on likely confidentiality, integrity, and availability impact.

- Justification: Brief explanation for the criticality assignment.

- Threat: A threat describes how a specific asset could be misused, compromised, or attacked in the context of this use case. Threats should be grounded in established attack knowledge (e.g., CAPEC).

Threat Fields

- Threat_ID: A unique identifier assigned to the threat (e.g., T1, T2, ...).

- Asset_ID: Identifier of the affected asset.

- Contextualized_Asset: The specific asset to which the threat applies (including relevant context if available from the use case).

- Threat_Description: A concise description of how the asset could be compromised in the context of the use-case flow.

- STRIDE_Categories: One or more applicable STRIDE categories for the same threat, separated by semicolons.

Allowed values: Spoofing; Tampering; Repudiation; Information Disclosure; Denial of Service; Elevation of Privilege

- Maps_to_Use_Case: The use-case identifier where the asset is involved and the threat could realistically occur.

- Source: The attack knowledge base used to ground the threat, such as "CAPEC".

- CAPEC_References: Zero, one, or many applicable CAPEC attack patterns. Each entry must include CAPEC ID and CAPEC name, separated by a colon. Multiple entries must be separated by semicolons.

- CAPEC_Rationale: Brief explanation of why each listed CAPEC mapping is relevant to the threat.

- Security Requirement: A security requirement is a specific, actionable, verifiable statement that mitigates or reduces the likelihood or impact of a threat.

Security Requirement Fields

- Requirement_ID: Unique identifier for the requirement (e.g., R1, R2, ...).

- Asset_ID: Identifier of the affected asset.

- Threat_ID: Identifier of the threat the requirement addresses.

- Security_Requirement: Specific, testable mitigation statement.
- Rationale: One-sentence explanation linking the requirement to the threat and asset.

CARDINALITY RULES

These rules are mandatory:

- An asset may have zero, one, or many threats.
- A threat must be tied to exactly one primary asset for traceability, but the same asset may appear in many threats.
- A threat may map to one or many STRIDE categories.
- A threat may map to zero, one, or many CAPEC references.
- A threat may have one or many security requirements.
- An asset may therefore have zero, one, or many security requirements across all associated threats.
- Do not force one-to-one relationships between assets, threats, CAPEC mappings, STRIDE categories, or requirements.
- Do not force the number of threats, CAPEC mappings, or requirements to be uniform across assets.
- Where multiple threats apply to the same asset, create separate threat entries.
- Where multiple requirements are needed for the same threat, create separate requirement entries with the same Threat_ID.
- Where multiple STRIDE categories apply to the same threat, list all applicable categories in STRIDE_Categories.
- Where multiple CAPEC mappings apply to the same threat, list all applicable mappings in CAPEC_References.
- If two attack scenarios are materially different in attacker action, preconditions, or impact, model them as separate Threat_IDs rather than forcing them into one threat.
- If multiple CAPEC entries describe alternative or complementary realizations of the same threat scenario, keep one Threat_ID and list all justified CAPEC mappings.

ANALYSIS RULES

- Use only information present in the use case.
- Do not invent architecture, protocols, deployment assumptions, tools, controls, or technologies.
- If a technology or tool is not explicitly stated, write Not Specified.
- If the use case does not support a defensible conclusion, write Insufficient Information.
- Ground threats in realistic misuse of the described workflow.
- Ground CAPEC mappings in authoritative CAPEC terminology where possible.
- Prefer precision over coverage inflation.
- Do not add CAPEC mappings unless they are plausibly supported by the threat description and use-case context.

- Do not invent threats merely to populate every asset.
- Do not invent requirements merely to force symmetry across threats.
- Requirements must be implementation-agnostic unless the use case explicitly names a technology.
- Requirements must be specific, actionable, and testable.
- Avoid vague wording such as secure, protect, handle safely, or ensure security unless followed by a measurable condition.
- Preserve traceability across sections by keeping IDs consistent.

TASK

Perform the following in one response:

Step 1: Asset Identification

- Identify all security-relevant assets in the use case.

Step 2: Criticality Assignment

- Assign each asset a criticality level based on likely CIA impact.

Step 3: Threat Identification

- Identify realistic, use-case-grounded threats for each asset using STRIDE.
- Do not assume every asset has a threat.
- Do not limit an asset to one threat.
- Do not limit a threat to one STRIDE category.
- Do not limit a threat to one CAPEC mapping.

Step 4: Security Requirement Derivation

- Derive one or more testable security requirements for each threat.
- Do not limit a threat to one requirement.

OUTPUT FORMAT:

Section 1: Assets table with fields:

Asset_ID, Asset_Name, Asset_Type, Tools/Techniques, Criticality, Justification

Section 2: Threats table with fields:

Threat_ID, Asset_ID, Contextualized_Asset, Threat_Description, STRIDE_Categories, Maps_to_Use_Case, Source, CAPEC_References, CAPEC_Rationale

Section 3: Security Requirements table with fields:

Requirement_ID, Asset_ID, Threat_ID, Security_Requirement, Rationale

OUTPUT RULES

- Output all three sections.
- Each section must be a syntactically valid CSV table.
- Keep IDs consistent across sections.
- In Section 2, include as many rows per asset as needed to represent all distinct threats.
- In Section 3, include as many rows per threat as needed to represent all distinct security requirements.
- Do not restrict any asset to a single threat.
- Do not restrict any threat to a single STRIDE category.
- Do not restrict any threat to a single CAPEC mapping.
- Do not restrict any threat to a single requirement.
- If a field contains multiple values, separate them with semicolons.
- If a field contains commas, semicolons, or quotes, quote the entire field properly for CSV validity.
- If no realistic threat can be identified for an asset, do not invent one.
- If no defensible CAPEC mapping exists for a threat, write Insufficient Information in CAPEC_References.
- If no defensible requirement can be derived for a threat, write Insufficient Information in the requirement field and explain why in the rationale.
- Do not include narrative commentary outside the three CSV sections.

Before producing the output, internally verify that you have not imposed any one-to-one mapping between Asset_ID, Threat_ID, CAPEC_References, STRIDE_Categories, or Requirement_ID.